LOT HW-001 ??? 02-API-CONTRACT

HW-001 ↔ lot-systems.com API Contract (proposed)

Existing code this builds on

- `POST /logs` in `src/server/routes/api.ts` takes `{ text, event?, metadata? }`, saves `Log` with a `context`, and is authenticated by the browser session (`req.user`). A device has no session, so it cannot call it as is.

New: device identity

- Table `Device { id, userId, name, tokenHash, lastSeenAt, fwVersion, createdAt }`.
- Pairing: user opens `/device` on the site, clicks “Add device”, and sees a 6-digit code plus a QR. The device camera scans the QR or the user types the code on the device. The device exchanges the code for a long-lived bearer token (`POST /api/device/pair`). Only a hash is stored on the server.
- All device calls use `Authorization: Bearer <device_token>`. Rate limit 60 requests/min per device.

Endpoints

Method	Path	Purpose
POST	`/api/device/pair`	`{code, hwId, fw}` → `{token, userName}`
GET	`/api/device/ws`	WebSocket. Server → device: `{type:"notify", id, text, ttl, haptic}`. Device → server: `{type:"ack", id}`
GET	`/api/device/poll?since=`	HTTPS fallback if WebSocket is blocked
POST	`/api/device/event`	`{type:"copy"|"photo"|"telemetry", notifyId?, text?, sensor?}`
POST	`/api/device/photo`	multipart JPEG, max 200 KB
GET	`/api/device/fw/latest`	OTA manifest `{version, url, sha256, sig}`

Copy button → Log tab

`POST /api/device/event {type:"copy", notifyId:"n_123", text:"Coffee time!"}` → server creates `Log { userId, text, event:"device_copy", metadata:{deviceId, notifyId, source:"HW-001"},`

`context }` using the same `getLogContext` helper. The Log tab renders `device_copy` entries with a small device mark.

Autonomous notifications

- Scheduler job per user: AI engine proposes a short nudge (max 60 characters, 2 lines on screen) based on time, weather telemetry, and recent logs. User rules: quiet hours, per-category mute.
- Admin or API manual send: `POST /api/device/notify {deviceId, text}`.

Telemetry

Device sends BME280 readings every 10 minutes: `{t, rh, p}`. Server stores them as the user's weather context and can feed the AI.

Security

TLS only, certificate pinning to the LOT CA. Token revocable on `/device`. Firmware OTA images are signed (ed25519); the device verifies before flashing.